Identity and Access Management

How identities reach the platform, and what they are entitled to do once they are there.

01 · 30 MIN
Identity model and federation

02 · 25 MIN
Automated provisioning with SCIM

03 · 20 MIN
Workload and automation identities

04 · 15 MIN
Entitlements and cluster policies

What this session covers

01	**Identity model and federation** Account and workspace identities, Entra ID single sign-on, and group design.	30 min
02	**Automated provisioning with SCIM** Joiner, mover and leaver flows, failure modes, and how access is evidenced.	25 min
03	**Workload and automation identities** Service principals, managed identities and personal access tokens.	20 min
04	**Workspace entitlements and cluster policies** What a principal can create and run, and how policies constrain it.	15 min

Identity first, entitlement second. Unity Catalog permissions on data come later in the day.

By the end, you will be able to

01 Describe how Entra ID single sign-on integrates with the Databricks account and workspaces.

02 Explain SCIM provisioning and the role of identity federation in keeping users and groups consistent.

03 Distinguish service principals from managed identities and select the right one for a given workload.

04 Describe workspace permission design and how cluster policies constrain what users can provision.

01

Identity model and federation

Where identities live, how they get here, and how they are grouped.

account vs workspace

Entra ID SSO

federation

group design

Identities live at two levels

ACCOUNT LEVEL

Who exists

One register of users, groups and service principals for the whole Databricks account. Created here, once.

WORKSPACE LEVEL

Who is present here

A subset of account principals, assigned to this workspace and given entitlements within it.

Create at the account, assign to the workspace. Creating users directly in a workspace produces duplicates that nothing else knows about.

How an identity reaches a workspace

Entra ID
Source of truth for people and groups.

→

SCIM provisioning
Copies users and groups in, and keeps them current.

→

Databricks account
Holds every principal, once.

→

Workspaces
Principals assigned where they need to work.

Authentication takes the same path in reverse: the user signs in against Entra ID, not against Databricks.

Three types of principal

Users

A person, identified by their work email address as held in Entra ID.

Groups

A collection of users, service principals or other groups. The unit permissions should be granted to.

Service principals

A non-human identity for jobs, pipelines and automation. No interactive sign-in.

All three are first-class: each can hold permissions, own objects and appear in the audit log by name.

Entra ID single sign-on

Azure Databricks **never holds a password** . Entra ID authenticates the person; Databricks authorises the principal it already knows.

Entra ID decides who

Credentials, MFA, conditional access, device compliance and sign-in risk are all evaluated there.

Databricks decides what

Workspace assignment, entitlements, cluster policies and Unity Catalog grants are evaluated here.

The sign-in flow

01 The user opens the workspace URL.

02 Databricks redirects the browser to Entra ID.

03 Entra ID authenticates the user and applies conditional access.

04 A signed token returns to Databricks and is validated.

05 The email in the token is matched to a provisioned principal. No principal, no session.

What has to be configured

IN AZURE

Enterprise application

Databricks appears in the tenant as an application. Conditional access policies attach here.

IN DATABRICKS

Unified login

All workspaces authenticate through the account, so there is one configuration to maintain and audit.

BEFORE YOU SWITCH

Emergency access

Agree who can still reach the account if the federation path breaks, and how that access is controlled.

What identity federation changes

WITHOUT FEDERATION

Identity per workspace

The same person exists several times, with different group memberships in each workspace and no single view of their access.

WITH FEDERATION

Identity at the account

Created once at the account and assigned to workspaces. One register to provision into, review and revoke from.

Federation is the precondition for a credible access review. Without it there is no one list to review.

Assigning principals to workspaces

ACCOUNT GROUP

Actuarial analysts

→

Development

Workspace access and cluster creation, within policy.

Test

Workspace access, no cluster creation.

Production

SQL access only.

One identity, different entitlements per environment. The identity is never duplicated to achieve it.

Grant to groups, not to people

An individual grant has **no lifecycle**. Nothing upstream knows it exists, so nothing removes it.

Group grant

Removed the moment the person leaves the group in Entra ID, as part of the HR process.

Individual grant

Survives moves and leavers, and is only ever found by someone auditing object by object.

> Group-based entitlement is the only pattern that stays correct without continuous manual effort.

Three dimensions of group design

Function

What the person does: analyst, engineer, steward, administrator.

Domain

Which data they work with: claims, policy, finance, reinsurance.

Environment

Where they work: development, test, production.

NAMING `dbx-claims-analyst-prod` The name should say what it grants without anyone opening it.

02

Automated provisioning with SCIM

Keeping the register current without anyone maintaining it by hand.

joiner mover leaver assurance

What SCIM is

A standard protocol for **pushing identity data** from a source system into an application. Entra ID pushes; the Databricks account receives.

Scheduled

It runs on an interval, not instantly. Expect a delay between a change in Entra ID and its effect here.

Scoped

Only the users and groups in scope are synchronised. Everything else does not exist in Databricks.

One direction

Changes made in Databricks are not pushed back, and will be overwritten or left orphaned.

Joiner

Created in Entra ID and added to their role group.

→

Next SCIM cycle creates the user in the Databricks account.

→

Group membership brings workspace assignment and data grants with it.

Correct access on the first morning, with no platform-team involvement. That is the point of the design.

Mover

REMOVED

Claims group

Every entitlement and grant that came through that group ends with the membership.

ADDED

Pricing group

The new role's access arrives on the same cycle, with no separate request.

> Anything granted to them individually survives the move. That accumulation is what an access review is looking for.

Leaver

IMMEDIATELY

Sign-in fails

Authentication is evaluated at Entra ID. Disabling the account there closes the interactive path at once.

ON THE NEXT CYCLE

Principal deactivated

SCIM deactivates the user in the Databricks account, which is what the access record will show.

The first is the control you rely on in an urgent case. The second is the one you evidence.

What deprovisioning does not remove

Objects they owned

Notebooks, dashboards and queries remain, with a deactivated owner.

Jobs in their name

A job that runs as a deactivated user fails, which is how most teams discover the ownership.

Automation they set up

Anything running as a service principal keeps running. Someone still has to own it.

> Production jobs and shared objects should be owned by service principals, so that a leaver is an identity change and not an outage.

Three common failure modes

Out of scope

The person exists in Entra ID but is not in scope of the provisioning job. Authentication works; access does not.

Group not synchronised

The user arrives without their group, so they land with no entitlements and no grants.

Nested membership

Membership held through a nested group may not arrive as expected. Assign the group that is actually in scope.

All three reach you as the same report: it does not work. Start the diagnosis at the provisioning log, not in the workspace.

Provisioning fails quietly

A stalled SCIM job raises nothing. It simply **stops making changes** — and the first change it stops making is removing leavers.

Monitor it as a service

Alert on provisioning errors and on a cycle that has not completed within its expected window.

Classify it correctly

A provisioning outage is an access-control incident, not an integration annoyance.

Evidencing grant and revoke

How is access granted?	The Entra ID group definition and the approval record behind membership.
How is it revoked?	The leaver process, plus the provisioning log showing the deactivation and its timestamp.
How do you know it worked?	The Databricks account user list, reconciled against Entra ID group membership on a stated cadence.

Three artefacts that agree. An undated manual reconciliation is not evidence.

03

Workload and automation identities

The identities that are not people, and which one belongs where.

service principals

managed identities

tokens

Why a job needs its own identity

A job that runs as a person **inherits that person's lifecycle**.

It breaks

The pipeline fails the week they leave, usually during a reporting cycle.

It drifts

Its permissions change whenever their role changes, for reasons unrelated to the job.

It misattributes

The audit log records a human as having read the data at three in the morning.

Service principals

A non-human account, created at the account and assigned to workspaces like a user. No interactive sign-in.

Databricks-managed

Created and held in the Databricks account. Quick to stand up; governed only by Databricks controls.

Entra ID application

Registered in our tenant, so it sits in the same directory, review cycle and reporting as every other identity.

Prefer the Entra ID route where it is available: one directory to govern, not two.

Secrets and OAuth

Client ID and secret

Held in Key Vault, referenced through a secret scope.

→

OAuth token request

Exchanged for a short-lived access token.

→

Token used

The short-lived token travels, not the secret.

> Secrets expire by design. Schedule the rotation, rather than discovering the expiry during a month-end run.

Azure managed identities

An identity whose credential **Azure holds and rotates**. There is no secret for us to store.

What it removes

No secret to store, distribute, leak or rotate — the most common source of credential exposure.

Where it applies

Only where the caller is an Azure resource that can hold one: Data Factory, Functions, the storage access connector.

The risk in a personal access token

A token carries the **full authority of the person who created it** , with none of the checks that person passes at sign-in.

No MFA

Holding the string is sufficient.

No conditional access

No device, location or risk evaluation applies.

Long-lived by habit

Pasted into a script, and outlives both the script and the person.

The controls over tokens

Disable creation

A workspace setting. The right default for production.

Restrict who can create

Grant the entitlement to a named group, not to all users.

Cap the lifetime

Set a maximum so tokens expire on a known schedule rather than never.

List and revoke

An admin can enumerate every token and revoke it. That list is what a review examines.

TARGET POSITION — No tokens in production, short-lived tokens in development, OAuth for everything automated.

Which identity for which job

A pipeline orchestrated by Azure Data Factory	**Its own managed identity**
A scheduled Databricks job or a CI deployment	**Service principal with OAuth**
Reading ADLS Gen2 from a workspace	**Access connector managed identity**
An engineer exploring interactively	**Their own sign-in**
Short-lived local development against the API	**A token, and never in production**

04

Workspace entitlements and cluster policies

What a principal can create and run, once it is inside.

admin roles

entitlements

cluster policies

Account admin and workspace admin

ACCOUNT ADMIN

The whole account

Creates workspaces, manages identities and federation, holds the metastore. A small named group, under privileged access management.

WORKSPACE ADMIN

One workspace

Entitlements, cluster policies, settings and objects within that workspace. Reasonably delegated to a team lead.

Neither role grants access to data. That is Unity Catalog, and it is granted separately.

The three entitlements

Workspace access

Can open the workspace at all. Without it, nothing else applies.

Databricks SQL access

Can use SQL warehouses, the query editor and dashboards.

Unrestricted cluster creation

Can create compute outside any policy. Rarely the right answer.

> Grant every entitlement to a group, and include the entitlement list in the access review — not just the user list.

What a cluster policy is

Rules that limit what a compute configuration **may contain** — so a user can create compute, but only compute that already complies.

Fix a value

Set it and remove the choice.

Restrict a value

Allow a list or a range, and reject anything else.

Hide a value

Keep it out of the interface so it is never a question.

What to constrain

Instance types	An approved family only, so nobody provisions a GPU cluster to run a SQL query.
Autoscaling limits	A maximum worker count, so a runaway job has a ceiling.
Runtime versions	A supported long-term-support runtime. A security control as much as a compatibility one.
Tags	Enforced, so every pound of compute spend is attributable to a cost centre.
Auto-termination	Mandatory and capped. The largest single saving available on the platform.

One control, three benefits

Security

A fixed supported runtime, no public IPs, no unapproved images or init scripts.

Cost

Enforced tags, a size ceiling and mandatory auto-termination.

Standardisation

One configuration shape to support, rather than every cluster being bespoke.

> The same artefact answers the security review, the cost conversation and the support model. Take it to all three.

Designing the policy set

Few policies

One per real use case: interactive development, job compute, SQL. Not one per team.

Granted to groups

Policy access is a permission like any other, and follows the same group pattern.

No standing exceptions

Unrestricted creation stays with platform administrators.

If a legitimate workload does not fit any policy, the policy set is wrong. Fix it rather than granting an exception.

Where that leaves you

You understand how identities flow from Entra ID into Databricks, what each identity type is for, and how workspace entitlements and cluster policies limit what principals can do.

Identity

Created at the account, federated to workspaces, kept current by SCIM.

Workload identity

Managed identities where available, service principals with OAuth elsewhere, tokens last.

Entitlement

Granted to groups, and constrained by a small set of cluster policies.

Engineering: you know which identity belongs in which workload, and what to ask for.

Assurance and service management: you know the three artefacts that evidence joiner, mover and leaver handling.

Next: from who can get in, to what they can see — Unity Catalog and data governance.

Lab 1: Designing Access — Who Needs What?

Ten scenarios from Contoso Retail's data platform team. No clicking — the focus is thinking through access before you build it.

Setup: Azure Databricks Premium with Unity Catalog. Catalogs "dev" and "prod", each with bronze, silver and gold schemas.

Description & Learning Objectives

In this lab you step into Contoso Retail's data platform team. You'll work through ten real-world access scenarios and choose the best design for each. There is no clicking in this lab. The focus is on thinking through access before you build it.

BY THE END OF THIS LAB, YOU WILL BE ABLE TO:

Tell apart Azure access (control plane) and Databricks data access (data plane)

Apply least privilege and group-based access

Choose the right identity for automated workloads

Design access that differs across environments and data sensitivity levels

Meet the Contoso Retail Team

Priya	Platform Admin
Dev	Data Engineer
Aisha	Data Analyst
Sam	Data Scientist
Omar	Customer Support Lead
sp-cicd-prod	Service principal for deployments

Setup: Azure Databricks Premium with Unity Catalog. Two catalogs, dev and prod, each with bronze, silver and gold schemas.

A new analyst joins

Contoso hires a second analyst, Neha, who needs the same access as Aisha. What is the best approach?

A Grant Neha the same table permissions Aisha has, one by one

B Add Neha to the Entra ID group grp-analysts, which is synced to Databricks and already holds the grants

C Make Neha a workspace admin so she can access what she needs

D Ask Aisha to share her personal access token with Neha

Answer: B

Groups scale. Joiners, movers and leavers are handled in Entra ID, not table by table.

”But I’m a Contributor!”

Dev has the Contributor role on the Azure resource group that contains the Databricks workspace. When he runs SELECT * FROM prod.gold.sales, he gets PERMISSION DENIED. Why?

A Contributor is a read-only role in Azure

B Azure RBAC controls the Azure resources, not the data governed by Unity Catalog

C Dev needs the Owner role on the subscription

D The SQL warehouse is switched off

Answer: B

Azure RBAC governs resources (control plane). Unity Catalog governs data (data plane).

Least privilege for the analyst

Aisha needs to query tables in prod.gold and build dashboards. Which access set follows least privilege?

A ALL PRIVILEGES on the prod catalog

B Workspace admin role

C USE CATALOG on prod, USE SCHEMA and SELECT on prod.gold, and Can Use on a SQL warehouse

D Storage Blob Data Reader on the ADLS Gen2 storage account

Answer: C

This is the full chain of grants needed and nothing more. D bypasses governance, and A and B over-grant.

The nightly job that broke

The nightly sales pipeline runs under Dev's user account. Dev leaves Contoso, his account is disabled, and the job fails the next night. What is the right design?

A Re-run the job under Priya's account

B Keep a shared "pipeline user" account with a password in a spreadsheet

C Run production jobs as a service principal, deployed through CI/CD

D Don't disable accounts of people who leave

Answer: C

Production should never depend on a human account. Service principals survive staff changes.

Same person, different environments

Dev builds and tests pipelines. What access should he have?

A Full rights in both dev and prod, so he is never blocked

B Create and modify rights in dev, and read-only (or no) access in prod, with changes promoted to prod by sp-cicd-prod

C No access to dev, and full access to prod

D Read-only in both, with Priya making every change

Answer: B

Freedom in dev and control in prod. Only automation changes production.

Protecting customer data

The prod.gold.customers table contains names, emails, phone numbers and region. Aisha needs trends but should not see contact details. Omar needs full contact details, but only for customers in his region (APAC). What is the best design?

A Create separate copies of the table for each team

B Give everyone SELECT and trust them not to misuse it

C Keep one table, apply a column mask on email and phone, and apply a row filter by region

D Deny Omar access, and ask Aisha to email him the data he needs

Answer: C

One governed table with different views avoids data copies and drift.

The password in the notebook

Sam's notebook connects to an external SQL database. His code contains the line password = "Contoso@123". What is the best fix?

A Move the password into a separate notebook that only Sam can open

B Store the password in Azure Key Vault and read it through a Key Vault-backed secret scope

C Encode the password in Base64 so it isn't readable

D Add a comment asking others not to copy the password

Answer: B

Secrets belong in Key Vault. Secret scopes keep them out of code and redact them in output.

The surprise cloud bill

Last month, several users created large GPU clusters and left them running overnight. Priya wants to control cost without blocking people from working. What should she do?

A Remove compute access for everyone except herself

B Create cluster policies that limit size, node type and auto-termination, and grant groups access only to those policies

C Email everyone a reminder to shut down clusters

D Delete all clusters every evening

Answer: B

Cluster policies set guardrails. Users stay productive and costs stay predictable.

The auditor’s request

Contoso's internal auditor, Omar's colleague Farah, needs to check who accessed customer data in the last 90 days. She should not be able to change anything. What should she get?

A Workspace admin role, so she can see everything

B SELECT on the prod.gold.customers table

C Read-only access to the audit system tables, such as system.access.audit

D The Owner role on the Azure subscription

Answer: C

Auditors need visibility, not control. System tables provide the evidence without granting access to the data itself.

Sharing data with a partner

Contoso's logistics partner needs daily access to the prod.gold.shipments table. The partner has its own Databricks environment on a different cloud. What is the best approach?

A Create Contoso user accounts for the partner's staff

B Export the table to CSV and email it every day

C Share the table using Delta Sharing, so the partner gets read-only access without copies or Contoso accounts

D Give the partner the storage account key

Answer: C

Delta Sharing gives governed, revocable, read-only access across organisations and clouds.